

****Supervision of Notification of Breach of Personal Data Security****

Date: 31-08-2023

Decision

Private Companies

No Criticism

Supervision / Self-initiated Case

Unintentional Disclosure

Notification of Breach of Personal Data Security

The Danish Data Protection Agency has conducted 16 planned inspections focusing on how municipalities and banks handle breaches of personal data security. The Danish Data Protection Agency found reason to express criticism in two cases.

Journal Number: 2021-41-0137.

Vestjysk Bank A/S (hereinafter Vestjysk Bank) was among the companies that the Danish Data Protection Agency selected for supervision in the autumn of 2021 under the General Data Protection Regulation[1] and the Data Protection Act[2].

The Danish Data Protection Agency's supervision was a written inspection that focused on whether Vestjysk Bank reports and documents breaches of personal data security in accordance with Article 33, paragraph 1, and Article 33, paragraph 5 of the General Data Protection Regulation, including the bank's processes for handling and recording breaches of personal data security. The supervision was based on an assessment of samples among unreported breaches as well as information about guidelines, procedures, and training activities, etc.

The supervision was announced to Vestjysk Bank by letter dated November 24, 2021, and the bank was simultaneously requested to answer a number of questions. The Danish Data Protection Agency informed about the background for the supervision, stating that a review of the agency's cases regarding notifications of breaches of personal data security revealed that Vestjysk Bank had reported significantly fewer breaches of personal data security per employee in the financial institution than other financial institutions.

By letter dated January 19, 2022, Vestjysk Bank sent a statement in which the bank responded to the Danish Data Protection Agency's questions. The bank's response was also accompanied by process descriptions and guidelines that the bank uses to comply with Article 33 of the General Data Protection Regulation.

****Summary****

In the summer and autumn of 2021, the Danish Data Protection Agency initiated written inspections of the handling of breaches of personal data security by eight larger municipalities and eight larger banks. The inspections were organized such that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the municipality's population and the number of employees in the bank.

"One of the new things that came with GDPR over five years ago was that data controllers, as a rule, must report all breaches of personal data security to the Danish Data Protection Agency within 72 hours, and they must also internally document all breaches of personal data security, regardless of whether they need to be reported to the Danish Data Protection Agency or not. Furthermore, there has been an increased focus on what companies and authorities need to consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, chief consultant at the Danish Data Protection Agency, and continues: "This can, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some samples. The conclusion is broadly that the 16 selected municipalities and banks seem to have the right focus on complying with the rules."

****Group with the Most Reported Breaches****

For the group with the most reported breaches, the inspections focused, among other things, on whether the municipalities and banks had taken appropriate security measures to reduce the number of breaches of personal data security, where there had been unauthorized disclosure of personal data in connection with sending information to, among others, citizens, authorities, etc., including in relation

to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not come to the knowledge of unauthorized persons. The data controller must, in this regard, ensure that all employees in the organization are familiar with any internal procedures for handling personal data, including in relation to sending personal data to, among others, citizens, authorities, etc.

Procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Danish Data Protection Agency found on the basis of the present information that all data controllers had taken appropriate security measures. In its assessment, the Danish Data Protection Agency emphasized that:

Procedures, etc. had been developed and activities had been carried out to educate employees in data protection, including to ensure that they are aware that there is no unintentional disclosure of personal data to an incorrect recipient.

They have considered and continuously implemented both technical and organizational measures following past breaches of personal data security to avoid similar breaches.

There is a strong focus on avoiding unintentional disclosure of confidential information, which both

****Supported by means of business processes, ongoing guidance, etc., and systematic measures, etc.****

****The group with the fewest reported breaches****

For the group with the fewest reported breaches, the inspections focused on whether the municipalities and banks report and document breaches of personal data security in accordance with the requirements of the General Data Protection Regulation (GDPR), including their processes for handling and recording breaches of personal data security.

The Data Protection Authority stated in these cases that it is the Authority's opinion that compliance with the rules that breaches of personal data security must, as a general rule, be reported to the Data Protection Authority within 72 hours entails that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this regard, the data controller must ensure that all employees in the organization are familiar with internal procedures for handling breaches of personal data security to the necessary extent, and that relevant employees can identify, manage, and assess breaches of personal data security.

The Data Protection Authority found that all data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have implemented appropriate training activities that can support compliance with the requirements of the GDPR regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are captured within the organization so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as to document the breaches, including the reasons for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that the Authority had not had the opportunity, as part of the inspection, to take a specific stance on whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training materials, including the content of, for example, ongoing awareness initiatives.

Furthermore, the Data Protection Authority stated that the rule requiring the data controller to document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security is complied with. Therefore, data controllers should document their justifications for all significant decisions made as a

result of the breach. This is particularly relevant if the data controller, after assessing the breach, concludes that it should not be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of individuals.

****Criticism in two cases****

As mentioned, criticism has been expressed in two of the cases – specifically regarding two municipalities that did not document all breaches of personal data security.

In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified during the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the recorded security incidents since September 2019 constitute actual breaches of personal data security.

In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality identified in 2018.

The Data Protection Authority notes that the list of breaches – in addition to serving as documentation for the Data Protection Authority – should also be used by the data controller to gain an overview of which breaches typically occur in the organization, and based on that, to consider whether, from a risk assessment perspective, there is a need to implement new or supplementary measures to avoid or further reduce the risk of additional breaches. It also appears from the received consultation responses that several data controllers actively use the lists for this purpose.

****1. Decision****

After reviewing the submitted material, the Data Protection Authority finds reason to conclude that Vestjysk Bank has, overall, adopted appropriate procedures and guidelines and has implemented appropriate training activities to correctly capture and handle breaches of personal data security, cf. Article 33 of the General Data Protection Regulation.

Below follows a more detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

****2. Justification for the Data Protection Authority's decision****

****2.1. Relevant legal provisions****

A breach of personal data security is defined in Article 4, No. 12 of the General Data Protection Regulation as a breach of security that leads to accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data that has been transmitted, stored, or otherwise processed.

It follows from Article 33, paragraph 1 of the General Data Protection Regulation that in the event of a breach of personal data security, the data controller must notify the Data Protection Authority without undue delay and, where feasible, no later than 72 hours after the data controller becomes aware of the breach of...

****Data Breach Notification Requirements****

1. In the event of a personal data breach, this must be reported to the supervisory authority competent in accordance with Article 55 (Data Protection Authority), unless it is unlikely that the breach poses a risk to the rights or freedoms of natural persons. If the notification to the supervisory authority is not made within 72 hours, it must be accompanied by a justification for the delay.

2. The Data Protection Authority holds the view that the requirement in Article 33 for breaches of personal data security to be reported to the Data Protection Authority within 72 hours implies that the data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly. The data controller must ensure that all employees in the organization are adequately familiar with internal procedures for handling breaches of personal data security, and

that relevant employees can identify, manage, and assess breaches of personal data security.

3. Furthermore, it follows from Article 33, paragraph 5 of the General Data Protection Regulation that the data controller must document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken. This documentation must enable the supervisory authority (Data Protection Authority) to verify that the provision has been complied with.

4. In the Data Protection Authority's guidance from February 2018 on handling breaches of personal data security, it is stated on page 27 that the requirements for documentation can be outlined as follows:

- Date and time of the breach.
- What happened in connection with the breach?
- What is the cause of the breach?
- What (types of) personal data are covered by the breach?
- What consequences does the breach have for the affected individuals?
- What remedial measures have been taken?
- Whether – and if so how – notification has been made to the Data Protection Authority? Why/why not?

5. The data controller should thus document its justifications for all significant decisions made as a result of the breach. This is particularly important if the data controller, after assessing the breach, concludes that it does not need to be reported to the Data Protection Authority. The documentation should in relation to this decision include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

****2.2. Assessment of Unreported Breaches****

6. Vestjysk Bank has, at the request of the Data Protection Authority, accounted for the first three breaches of personal data security that occurred in 2021, which the bank failed to report to the Data Protection Authority.

7. The first incident concerned that, in connection with a data breach at BEC Financial Technologies, information was not forwarded to Vestjysk Bank regarding any address protection for existing customers who had been assigned a new personal identification number. This was due to the fact that when a customer changed their CPR number, they were not registered for CPR monitoring, meaning that BEC and thus the bank did not receive information about any registration of name and address protection. Consequently, there was a risk that the bank did not treat the customer as address-protected. This was primarily significant when a customer made bank transfers themselves, as the customer's address information is sent along if the address is not protected. The bank identified that there were four affected customers. After reviewing the affected customers, Vestjysk Bank found that three customers did not have active accounts, meaning that no transfers could have been made where address information was incorrectly sent, and that the fourth customer with an active account did not have address protection.

8. The second incident involved the bank being informed via BEC that e-Boks had a system error between February 8 and 11, 2021, which resulted in mail forwarded from e-Boks being accessible to an incorrect recipient. Vestjysk Bank, upon contacting e-Boks, discovered that there were two affected transmissions. An investigation of the content showed that the documents did not contain personal data.

9. The third incident involved an employee mistakenly sending an Excel sheet containing 79 personal identification numbers and corresponding customer numbers to a recipient list consisting of several customers. Vestjysk Bank then determined that 22 customers had opened the message before Vestjysk Bank deleted the message from the remaining recipients. The bank could not see whether the customers had opened the attached file. Vestjysk Bank, in its assessment of the nature of the breach, emphasized that the individuals whose personal identification numbers were disclosed could not be

identified by name or address, etc., and that the bank trusts the recipients, including that they have deleted the message upon request.

10. The Data Protection Authority does not find that the first two incidents constitute a breach of personal data security. The Data Protection Authority has emphasized that the reported incidents do not constitute a breach of established security measures that have led to accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data that has been transmitted, stored, or otherwise processed, cf. the definition in Article 4, paragraph 1, no. 12 of the General Data Protection Regulation.

11. The Data Protection Authority does not find grounds to override Vestjysk Bank's assessment that the third incident can be characterized as a breach of personal data security, cf. Article 4, no. 12 of the General Data Protection Regulation, but that it is not subject to the obligation to report.

12. Thus, the Data Protection Authority does not find grounds to override the assessment that it must be designated as...

unlikely that the breaches in question involve a risk to the rights and freedoms of natural persons, cf. Article 33, paragraph 1. The Data Protection Authority has particularly emphasized that private individuals would generally not be able to identify customers based on the information provided (CPR number, customer number, and information that they were customers of Vestjysk Bank). Vestjysk Bank has also referred to the fact that the information ended up with recipients whom the bank trusts and who are expected to destroy the information according to the bank's instructions. In this context, Vestjysk Bank has referred to the Data Protection Authority's guidance on handling breaches of personal data security, which states that if information has ended up with a recipient whom the data controller has great trust in and expects will return or destroy the information according to the instructions from the data controller, this may lead the data controller to assess that there are no consequences associated with the disclosure, and therefore, there is no need to report to the Data Protection Authority. It is also stated in the guidance that the data controller should be certain in their case when the recipient's credibility is given significance for this assessment. The Data Protection Authority notes in this connection that it is the Authority's opinion that a general customer relationship between a bank and its customers does not in itself create such credibility with the recipient that it can be assumed without further consideration that the breach does not involve a risk to the rights and freedoms of natural persons.

2.3. Documentation, procedures, and employee training

Vestjysk Bank has stated in the statement of January 19, 2022, that since May 25, 2018, and up to January 19, 2022, a total of 62 breaches of personal data security have been identified, which Vestjysk Bank has stated also includes breaches at Den Jyske Sparekasse, with which Vestjysk Bank merged at the beginning of 2021.

Furthermore, it appears from the statement of January 19, 2021, and the attached documents, that Vestjysk Bank has established procedures for how and to whom breaches of personal data security should be reported internally within the organization, whom employees can contact with questions about breaches, who is responsible for receiving, handling, and assessing breaches, as well as for reporting to the Data Protection Authority.

It is also stated that Vestjysk Bank has developed business processes and conducted a number of activities to educate employees in data protection, including with the aim that they will be able to identify and handle any breaches of personal data security. Vestjysk Bank has also explained the criteria that are included in the municipality's assessment of whether a breach of personal data security should be reported to the Data Protection Authority.

Based on the submitted material, including information about the unreported breaches from 2021, the Data Protection Authority's immediate assessment is that Vestjysk Bank has overall adopted appropriate procedures and guidelines, etc., and has conducted appropriate training activities that can support compliance with the requirements of Article 33 of the General Data Protection Regulation, and which can thus ensure that breaches of personal data security are captured within the organization, so

that they can be assessed as to whether the breach should be reported to the Data Protection Authority, as well as documentation of the breaches can be made, including, among other things, the justification for not reporting them to the Data Protection Authority.

It is noted that the Data Protection Authority has not had the opportunity as part of the supervision to take a specific position on whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data. (Data Protection Act)